Secrets

English version of ../../security/secrets.md.

Incident: a GigaChat key was committed

What happened. The `.env` file was under version control even though `.gitignore` contained an explicit "Secrets — NEVER commit". It held a working `GIGACHAT_CREDENTIALS` (a base64 key of the form `client_id:client_secret`), plus `SECRET_KEY`, `ADMIN_SECRET_KEY` and `CHEAT_TESTER_CODE`. The file changed across 8 commits.

What was done. 1. `.env` was removed from the index (`git rm --cached .env`) — new commits no longer contain it. 2. Secret scanning was added to CI (`.github/workflows/ci.yml`, job `secrets`, `gitleaks` with `.gitleaks.toml`). 3. `scripts/doctor.sh` checks that `.env` is not tracked by git. 4. The "do not commit" instruction was replaced with a check that fails on a pull request.

What the owner must do. Deleting the file **does not revoke the key**: it stays in the git history and may have been copied.

1. Reissue `GIGACHAT_CREDENTIALS` in the GigaChat Studio console.
2. Change `SECRET_KEY` (session signing), `ADMIN_SECRET_KEY`, `CHEAT_TESTER_CODE`.
3. Check GigaChat logs for calls made with this key.
4. Decide the fate of the history: a rewrite (`git filter-repo`) rewrites commits and requires coordinated action from everyone who has a clone. The acceptable minimum is to treat the key as compromised and rotate it.

History was cleaned (2026-10-29, by the owner's decision). `git filter-repo` removed the `.env` path from all 99 commits, rewrote all refs (branches) and force-pushed the result. Verification on a fresh clone: `gitleaks git` — 0 findings.

Caveats that remain after the rewrite:

1. **The key must still be reissued.** It was publicly available; cleaning the history removes it from the repository but does not undo the leak.
2. **GitHub pull request refs cannot be rewritten.** PR #1 is already merged, and `refs/pull/1/head` points at a commit from the old history and cannot be updated (`deny updating a hidden ref`). Objects from that ref stay reachable by SHA until GitHub garbage-collects them. Removing them permanently requires a GitHub Support request ("removing sensitive data") — an action of the organisation owner, not something a repository can do.
3. Anyone who had a clone before the rewrite must delete it and clone again: the old `.env` object also sits in their local folder.

Rules for this project

Secret	Where it lives	Consequence of a leak
`SECRET_KEY`	`.env` / environment	session forgery
`ADMIN_SECRET_KEY`	`.env` / environment	access to admin functions
`CHEAT_TESTER_CODE`	`.env` / environment	bypassing game rules
`GIGACHAT_CREDENTIALS`	`.env` / environment	spending the GigaChat quota

1. Secrets are provided through the environment only. The repository holds just `.env.example` with placeholders.
2. A missing secret disables a feature instead of creating an unsafe mode: without `GIGACHAT_CREDENTIALS` the AI features are unavailable and the game works.
3. Compose requires the mandatory secrets (`${VAR:?…}`) and fails without them — that is protection, not inconvenience.